

HiveForce Labs

THREAT ADVISORY

 **VULNERABILITY REPORT**

Critical GitLab Flaw Lets Attackers Hijack User Pipelines

Date of Publication

July 12, 2024

Admiralty Code

A1

TA Number

TA2024270

Summary

First Seen: July 2024
Affected Products: GitLab Community Edition (CE) and Enterprise Edition (EE)
Impact: GitLab has issued a warning about a critical vulnerability in its GitLab Community and Enterprise editions. This flaw, identified as CVE-2024-6385, allows attackers to run pipeline jobs as any other user. The vulnerability has been patched in the latest security update released and carries a CVSS base score severity rating of 9.6 out of 10.

CVE

CVE	NAME	AFFECTED PRODUCTS	ZERO-DAY	CISA	PATCH
CVE-2024-6385	GitLab CE/EE Improper Access Control Vulnerability	GitLab Community Edition (CE) and Enterprise Edition (EE)			

Vulnerability Details

- #1

GitLab has alerted users to a major security flaw in its Community and Enterprise editions. This vulnerability, identified as CVE-2024-6385, allows attackers to run pipeline jobs pretending to be any user they choose. GitLab has fixed this issue in the latest security update, giving it a severity rating of 9.6 out of 10.
- #2

This flaw affects all versions of GitLab's Community and Enterprise editions. GitLab pipelines are a key feature of their CI/CD system, helping users automate tasks like building, testing, and deploying code. The CVE-2024-6385 vulnerability lets remote attackers access restricted features in GitLab by bypassing security measures. They can exploit this flaw to run pipeline jobs as any user, potentially gaining higher privileges or interfering with sensitive operations.

#3

Recently, GitLab patched a similar vulnerability (CVE-2024-5655) in late June. Both vulnerabilities allow attackers to run pipelines as other users due to inadequate access restrictions. To address these risks, GitLab has released security updates for both Community and Enterprise editions, including versions 17.1.2, 17.0.4, and 16.11.6. Administrators should upgrade their installations immediately to protect against these threats and ensure secure operations.

Vulnerability

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2024-6385	Gitlab Community Edition and GitLab Enterprise Edition Versions 15.8 prior to 16.11.6 Versions 17.0 prior to 17.0.4 Versions 17.1 prior to 17.1.2	cpe:2.3:a:gitlab:gitlab:*:*:*:community:*:*:* cpe:2.3:a:gitlab:gitlab:*:*:*:enterprise:*:*:*	CWE-284

Recommendations



Update: To mitigate the risk posed by CVE-2024-6385 update GitLab Community Edition (CE) and Enterprise Edition (EE) to the latest version 17.1.2, 17.0.4, 16.11.6, which addresses the vulnerability. Users are strongly advised to update to this version to reduce the risk of exploitation.



Vulnerability Management: Implement a robust vulnerability management process to ensure that software and systems are regularly assessed for vulnerabilities and updated with the required security patches. Prioritize critical vulnerabilities identified by security advisories and vendors to mitigate the risk of exploitation by threat actors.

Potential MITRE ATT&CK TTPs

<u>TA0042</u> Resource Development	<u>TA0001</u> Initial Access	<u>TA0002</u> Execution	<u>TA0004</u> Privilege Escalation
<u>T1588</u> Obtain Capabilities	<u>T1588.006</u> Vulnerabilities	<u>T1068</u> Exploitation for Privilege Escalation	<u>T1190</u> Exploit Public-Facing Application

Patch Details

To mitigate the risks posed by CVE-2024-6385 it is crucial to update GitLab Community Edition (CE) and Enterprise Edition (EE) to their latest versions 17.1.2, 17.0.4, 16.11.6, which have been patched to address the vulnerability. Users are strongly advised to perform these updates promptly to minimize the risk of exploitation.

Link: <https://about.gitlab.com/releases/2024/07/10/patch-release-gitlab-17-1-2-released/>

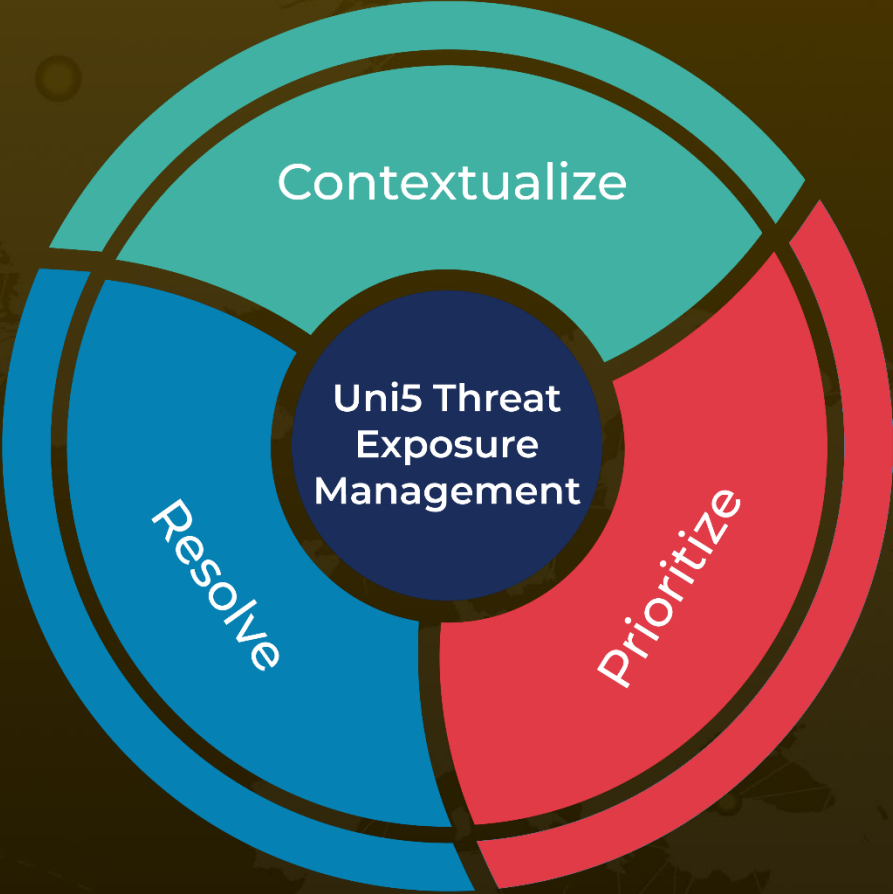
References

<https://about.gitlab.com/releases/2024/07/10/patch-release-gitlab-17-1-2-released/#an-attacker-can-run-pipeline-jobs-as-an-arbitrary-user>

What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with HivePro Uni5: Threat Exposure Management Platform.



REPORT GENERATED ON
July 12, 2024 • 5:50 AM

© 2024 All Rights are Reserved by Hive Pro



More at www.hivepro.com